Prayog — Security and Threat-Model Report

CS455 Deliverable 3 · Group 3 · 6 November 2026

1. Scope and method

System under analysis: `main` of `Dishaswamy/Prayog` at `18767aa` (PR #26 merged) plus the D3 fixes on branches `d3-testing` (commit `f358e01`) and `d3-final`. Four activities, all run on 6 November 2026:

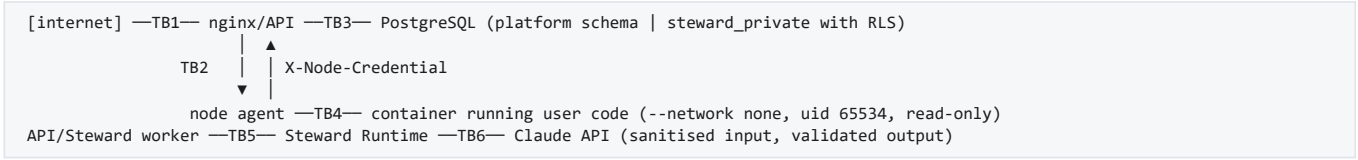
1. **Threat model** — assets, actors and trust boundaries from the SADD (section 2–3), then STRIDE per boundary (section 4), each threat mapped to its control and to the test that proves the control.
2. **Static analysis** — `bandit 1.9.4` over 20,187 lines of application code (backend, Steward, CLI; tests and migrations excluded), every Medium/High finding triaged by reading the code (section 5).
3. **Dependency audit** — `pip-audit` against `backend/requirements.txt` (49 packages), the `steward` and `cli` packages (section 6).
4. **Adversarial testing** — 23 black-box probes (37 cases) against a running API with test accounts (section 7), and the automated security regression tests in the suites (section 8), including `test_cases/gpu/scheduler/test_security.py` and `test_adversarial.py`, which use real tokens and found D3-16 to D3-20.

2. Assets

Asset	Why it matters	Where it lives
User credentials, sessions	account takeover, impersonation	Argon2 hashes (`pwdlib` recommended parameters) in `users`; JWT (HS256, 60 min, `jti` revocable)
Research code, datasets, weights, results (IP)	unpublished research; a student's grade	artifact store (content-addressed, BLAKE3/SHA-256 verified), snapshot tables
Run logs and Steward diagnoses	can contain paths, hyper-parameters, secrets printed by user code	`run_logs`, `steward_private.*` under row-level security
GPU capacity and fair share	the scarce resource the platform allocates	scheduler tables; node agents
Node credentials	a stolen credential lets an attacker report fake results or receive other users' code	SHA-256 hash in `nodes.credential_hash`; plaintext only on the node
Audit trail	accountability for approvals, cancellations, admin actions	`audit_events`, append-only by trigger
Secrets: `JWT_SECRET_KEY`, DB passwords, `ANTHROPIC_API_KEY`	total compromise	`.env` (git-ignored); the Steward Runtime gets only the model key

3. Actors and trust boundaries

Actor	Trust	Can reach
Anonymous internet user	none	`/auth/register`, `/auth/login`, password reset, `/app` static files, `/health`
Student / Researcher	own records only; may submit only with approved, unexpired access	`/jobs`, `/mlflow/*`, `/rebuilds`, `/steward/*` (own)
Professor	supervised users' metadata, read-only	`/mlflow/professor/*`, access-request decisions naming them
Platform Admin	pool operations, approvals; **never** project content	`/admin/*`
Node agent (lab machine)	one node's allocations only	`/agent/*` with `X-Node-Credential`
User code inside a run	**hostile by assumption**	its container only
Steward Runtime / Claude	output untrusted, validated by the server	nothing but the scoped, sanitised input it is sent



4. STRIDE analysis

ID	Boundary	Threat (STRIDE)	Control in the code	Evidence
T01	TB1	**S** — credential guessing	Argon2; 10 failures lock the account for 15 min, same 401 for all failures (FR-AUTH-60, fix D3-02); lockout counter updated under a row lock	`test_review_fixes` (4 tests), concurrency C4 (25 parallel guesses lock once), probe A19
T02	TB1	**S** — forged or replayed token	HS256 with a required secret (startup fails without it); `algorithms=[HS256]` pinned; `exp` and `sub` required, so a token with no expiry is refused (fix D3-19); `jti` revoked on logout; `ver` bumped on password change	probes A07–A13, `test_auth_routes`, `test_review_fixes::test_a_session_ends_when_*`
T03	TB1	**E** — role claim in token trusted	role read from the database row, the token's `role` is informational	probe A11
T04	TB1	**I** — account enumeration	identical 401 for unknown account, wrong password, wrong role, lockout; dummy hash verified for unknown accounts (constant work)	`test_login`, probe A19
T05	TB1	**I/E** — IDOR on jobs, runs, snapshots, diagnoses	every query filters by owner; a foreign object reads as 404, identical to a missing one (NFR-GPU-030). `POST /jobs/{id}/cancel` used to answer 403 for another user's job; it now answers the same 404, and the refusal is audited (fixes D3-13, D3-20)	probes A01–A03b; `test_security::test_another_users_job_cannot_be_read_edited_or_cancelled`, `test_a_refused_cancel_leaves_an_audit_record`; `test_mlflow_rebuild_preinit`, `test_steward_context`
T06	TB1	**E** — student reaches admin API	`require_roles("ADMIN")` on every `/admin` route	probes A04–A05, `test_admin_*`
T07	TB1	**T** — SQL injection	SQLAlchemy bound parameters throughout; the two string-built statements use table names from a constant tuple (bandit B608, triaged false positive)	probe A14, section 5
T08	TB1	**D** — expensive input (hashing 100 kB passwords, absurd GPU counts)	Pydantic limits (password ≤ 128, email ≤ 255); walltime regex; GPU count checked against the largest node	probes A15–A16
T09	TB1	**T** — mass assignment (client sets lab, account type, state)	lab and account type come from `scheduling_contexts`, never the request; extra fields ignored	probe A17
T10	TB1	**I** — path traversal in the static web app	files served from a fixed directory by name	probe A18
T11	TB1	**T** — cross-site requests	CORS allow-list (`localhost:3000/5173`); Steward cookie mutations need `X-Steward-CSRF`	probe A20

ID	Boundary	Threat (STRIDE)	Control in the code	Evidence
T12	TB1	**I/T** — click-jacking, MIME sniffing, injected scripts in the web app	`integration/web.py` sends a strict CSP (`default-src 'self'`, `frame-ancestors 'none'`), `nosniff`, `X-Frame-Options: DENY`, `Referrer-Policy: no-referrer`, `Cache-Control: no-store` on `/app`	probe A21
T13	TB2	**S** — fake node agent	one-time enrolment token (hashed, expiring) exchanged for a node credential (hashed); every agent call names its node	`test_gpu_agent_api` (26 tests)
T14	TB2	**T** — agent reports another node's allocation	allocation lookups scoped to the authenticated node	`test_gpu_agent_api`
T15	TB2	**E** — user token on agent API	agent routes require `X-Node-Credential`, user JWT refused	probe A06
T16	TB4	**E** — user code escapes the container	`--network none --read-only --cap-drop ALL --security-opt no-new-privileges --pids-limit --memory --cpus --user 65534:65534`, `--pull=never`	CI "real hardened container" tests
T17	TB4	**T** — local user on the node tampers with a run's output	run workspace closed to `0700` (fix D3-05); output verified by checksum before upload; symlinks and non-regular files never shipped	`test_node_agent_units` (POSIX check), `test_a_symlink_*`
T18	TB4	**T** — malicious archive (zip slip, symlinks, manifest mismatch)	every path normalised and checked, symlinks refused, every chunk and file verified against the manifest	`test_node_agent_units` (13 refusal tests), `test_staging` (27)
T19	TB3	**I** — one user's Steward data read by another through a bug	`steward_private` row-level security; the Steward connects as `NOSUPERUSER NOBYPASSRLS` and `setup_steward` refuses otherwise	Steward integration suite (PRAYOG-101)
T20	TB3	**R** — admin denies a cancellation or approval	append-only `audit_events` (UPDATE/DELETE refused by trigger, even for the owner role)	`test_admin_cancel_job`, Steward audit tests
T21	TB5/6	**I** — secrets or code leave in model prompts	two-stage sanitiser before every egress (ADR-S03); raw logs never leave the server	Steward unit tests (PRAYOG-96)
T22	TB5/6	**T/E** — prompt injection in a log makes the Steward act	the Steward has no write or execution authority; proposals change only GPU count and walltime and need the owner's approval; uncited claims dropped (ADR-S04)	PRAYOG-97, PRAYOG-98 tests
T23	all	**D** — database outage or pool exhaustion	503 + Retry-After instead of a 500 or a 30 s hang; pool sized to the thread pool (fixes D3-06, D3-07)	`test_database_unavailable`, Performance report

ID	Boundary	Threat (STRIDE)	Control in the code	Evidence
T24	TB2	**D** — control-plane outage looks like node failure	the reaper judges silence only when the platform was able to listen (fix D3-08)	`test_liveness` (9), failure experiment (Failure report section 5)
T25	TB1	**E** — claiming someone else's snapshot by naming it on a job, then rebuilding it	a snapshot the ledger holds is rebuildable only through the ledger's ownership check; the answer is the same generic rejection (fix D3-18)	`test_adversarial::test_naming_someone_elses_snapshot_on_a_job_does_not_let_you_rebuild_it`
T26	TB1, TB2	**D** — hostile values crash a request: NUL characters, numbers beyond a column's range	400 `INVALID_VALUE` on every route, 422 on agent reports; generic text, cause in the log (fixes D3-16, D3-17)	`test_adversarial` (8), `test_security::test_invalid_values_never_echo_internals`
T27	TB1	**T** — SQL in a stored field; **E** — a course member choosing a lab, pool or priority	bound parameters; lab, account type and owner come from server-side records	`test_security::test_sql_in_a_field_is_stored_as_text`, `test_a_course_member_cannot_choose_a_lab_pool_or_priority`

5. Static analysis (bandit)

50 findings: 1 High, 6 Medium, 43 Low. Every Medium and High finding was read in context:

Finding	Location	Verdict
B103 High — `chmod 0o777`	`node_agent/workspace.py:135` (run output dir)	**Real weakness → fixed (D3-05).** The mode is needed so uid 65534 inside the container can write, but the workspace around it was world-traversable. The workspace is now `0700`.
B103 Medium — `chmod 0o555`	`mlflow_worker.py:312` (input dir)	Intended: read-only, executable directory for the container. Not a weakness.
B108 Medium ×2 — `/tmp`	`mlflow_worker.py:338`, `node_agent/runners.py:115`	False positive: these are `--tmpfs /tmp:rw,noexec,nosuid` mounts *inside* the container, not host temp files.
B314 Medium — `xml.etree.ElementTree.fromstring`	`steward/.../knowledge/arxiv.py:38`	Low risk: parses the arXiv API's Atom feed over HTTPS. Python's bundled expat protects against entity expansion; switching to `defusedxml` is recorded as hardening item S-03.
B608 Medium ×2 — SQL built with f-string	`steward/.../retention.py:30,49`	False positive: the table name comes from a constant tuple; values are bound parameters.
43 Low	asserts in non-test code (14), `subprocess` without shell (16), default-password parameter names (7), others	Reviewed in bulk: subprocess calls use argument lists without a shell; the "passwords" are parameter names, not values.

6. Dependency audit

`pip-audit` reported **no known vulnerabilities** in the 49 pinned backend requirements, the Steward package or the CLI package (6 November 2026, PyPI advisory database). CI does not yet run it; adding `pip-audit` and `bandit -ll` as a CI step is item S-04.

7. Adversarial probes (live)

Script `evidence/adversarial.py`, with test accounts only. Each probe states the safe behaviour before it runs. On `d3-testing`, 36 of 37 cases passed and A03b failed (defect D3-13). **37 of 37 adversarial probes pass on the final build** (`evidence/adversarial_final.json`); the table below shows the earlier run.

ID	Category	Attack	Expected safe behaviour	Observed	Result
A01	IDOR	bob reads alice's job by ID	404, same as a missing job	404	**PASS**
A02	IDOR	existence oracle: foreign vs missing job	identical status and body	404/404	**PASS**
A03	IDOR	bob cancels alice's job	refused; job unchanged	403, job QUEUED	**PASS**
A03b	IDOR	existence oracle on cancel: foreign vs missing job	identical status (404), as for reads	403/404	**FAIL**

ID	Category	Attack	Expected safe behaviour	Observed	Result
A04	privilege escalation	student GET /admin/pool	403	403	**PASS**
A04	privilege escalation	student GET /admin/nodes	403	403	**PASS**
A04	privilege escalation	student GET /admin/alerts	403	403	**PASS**
A05	privilege escalation	student registers a GPU node	403/422, nothing created	403	**PASS**
A06	privilege escalation	user token on node-agent API	401/403	401	**PASS**
A07	token forgery	alg=none token	401	401	**PASS**
A08	token forgery	token signed with a guessed key	401	401	**PASS**
A09	token forgery	payload sub changed, signature kept	401	401	**PASS**
A10	session	expired token (correctly signed)	401	401	**PASS**
A11	privilege escalation	validly signed token claiming role ADMIN for a student	403 (role read from DB)	403	**PASS**
A12	session	token reused after logout	401	401	**PASS**
A13	session	a second login survives the first one's logout	200	200	**PASS**
A14	SQL injection	login email "' OR '1'='1' --"	401/422, never 200 or 500	401	**PASS**
A14	SQL injection	login email "alice@iitk.ac.in' --"	401/422, never 200 or 500	401	**PASS**
A14	SQL injection	login email 'admin@iitk.ac.in"; DROP TABLE users; --'	401/422, never 200 or 500	401	**PASS**
A15	input validation	100 kB password (hashing DoS)	422 before hashing	422	**PASS**
A16	input validation	gpus=-1 walltime='00:30'	4xx with a reason	400 INVALID_GPUS	**PASS**
A16	input validation	gpus=0 walltime='00:30'	4xx with a reason	400 INVALID_GPUS	**PASS**
A16	input validation	gpus=1000000000 walltime='00:30'	4xx with a reason	400 GPUS_EXCEED_MAX_NODE	**PASS**
A16	input validation	gpus=1 walltime='999:99'	4xx with a reason	400 INVALID_WALLTIME	**PASS**
A16	input validation	gpus=1 walltime='00:00'	4xx with a reason	400 INVALID_WALLTIME	**PASS**
A16	input validation	gpus='1; DROP' walltime='00:30'	4xx with a reason	400 INVALID_GPUS	**PASS**
A16	input validation	gpus=1 walltime='1e9'	4xx with a reason	400 INVALID_WALLTIME	**PASS**
A17	mass assignment	submit with lab_id/state/user_id fields	extra fields ignored or refused	201	**PASS**
A18	path traversal	GET /app/../main.py	no source or secrets served	404	**PASS**
A18	path traversal	GET /app/%2e%2e/main.py	no source or secrets served	404	**PASS**
A18	path traversal	GET /app/..%2fmain.py	no source or secrets served	404	**PASS**
A18	path traversal	GET /app/%2e%2e%2f%2e%2e%2f.env	no source or secrets served	404	**PASS**
A18	path traversal	GET /app/web.css/../../database.py	no source or secrets served	404	**PASS**
A19	brute force	11 wrong passwords then the right one	right password refused during lockout, same 401	{401} then 401	**PASS**
A20	CORS	preflight from an unlisted origin	no Access-Control-Allow-Origin	None	**PASS**
A21	hardening	security headers on the web app	nosniff, frame and CSP headers present	all present	**PASS**
A22	error handling	malformed path parameter	422 without a stack trace	422	**PASS**

8. Security regression tests in the suites

Area	Tests	Result (6 Nov, PostgreSQL)
Authentication, sessions, lockout, password reset	`test_auth_routes` (10), `test_login` (13), `test_password_reset` (15), `test_review_fixes` (14), `test_cli_login` (9)	all pass
Authorization and isolation	`test_access_request_purpose` (22), `test_admin_*` (8), `test_mlflow_professor_*` (26), `test_steward_context` (5), `test_mlflow_rebuild_preinit` (3)	all pass
Untrusted archives and outputs	`test_node_agent_units` (49), `test_staging` (27), `test_mlflow_worker` (7)	pass on Linux (CI); 8 fail on Windows only (symlink privilege, `killpg`, POSIX modes)
Diagnostic links	`test_diagnostic_session_audit` (6)	pass on Linux; 1 Windows path-separator failure
Concurrency of security-relevant state	C1 (idempotency), C4 (lockout under 25 parallel guesses)	pass, 3 runs

9. The authorization-abuse scenario, shown and prevented

Scenario A-18. Bob tries to cancel Alice's job, with his own valid token.

1. `POST /jobs/{id}/cancel` reaches the server; the job row is locked and its owner checked.
2. Bob gets `404 Job not found.`, byte for byte what he gets for a job that does not exist.
3. The job is untouched, and `audit_events` gains a row: Bob's ID, `job.cancel`, `job:{id}`, `REFUSED`.

Testing this scenario found two real defects: the different status code (D3-13, by Areen's probe A03b), and the missing audit row (D3-20). Both are fixed. Note that FR-GPU-065 says "insufficient permission" while NFR-GPU-030 says another user's job reads as not found; we followed NFR-GPU-030 because it closes the enumeration, and the audit row keeps the refusal on record.

A second scenario, D3-18, was a real hole. Alice named Bob's snapshot ID on `POST /jobs`, then called `POST /rebuilds` on it and got `201` with a rebuild attempt. It worked because the fallback for "a snapshot one of your jobs ran" trusted a field the client supplies. It now answers the same generic rejection as any other foreign snapshot.

10. Residual risks and open items

ID	Item	Risk	Action
S-02	`/metrics` unauthenticated	leaks pool size and queue depth (counts only)	restrict at the proxy
S-03	`xml.etree` for arXiv feeds	low	`defusedxml`
S-04	No security scanning in CI	regressions unnoticed	add `pip-audit` and `bandit -ll` steps
S-05	No email verification at registration	accounts for addresses not owned (mitigated: nothing can be done without professor + admin approval)	verify `@iitk.ac.in` ownership by OTP
S-06	Owners can self-declare a rebuild via `PATCH /mlflow/rebuilds` (from the 2 Nov review)	integrity of the reproduction record	server-side derivation only
S-09	No rate limiting by IP	an attacker can lock an account on purpose, or spam registration	limit `/auth/*` at the reverse proxy
S-10	Seed scripts set known passwords	an instance seeded this way is open to anyone who knows the rule	never run them on a deployed instance (Deployment section 4)
S-08	The web app keeps the JWT in `sessionStorage` (one tab, cleared on close)	token theft if an XSS is ever introduced (none found; the strict CSP blocks inline and third-party scripts)	HttpOnly cookie sessions later